



WILLIAM STALLINGS

EFFECTIVE CYBERSECURITY

1ST EDITION

CHAPTER 2

Security Governance





GOVERNANCE

- **Establishment** of policies and
- continuous **monitoring** of their proper implementation by the members of the governing body of an organization.
- Governance includes the mechanisms required to balance the powers of the members and their primary duty of enhancing the prosperity and viability of the organization.



SECURITY PROGRAM

The management, operational, and technical aspects of protecting information and information systems. A security program **encompasses policies, procedures, and management structure and mechanism** for coordinating security activity.

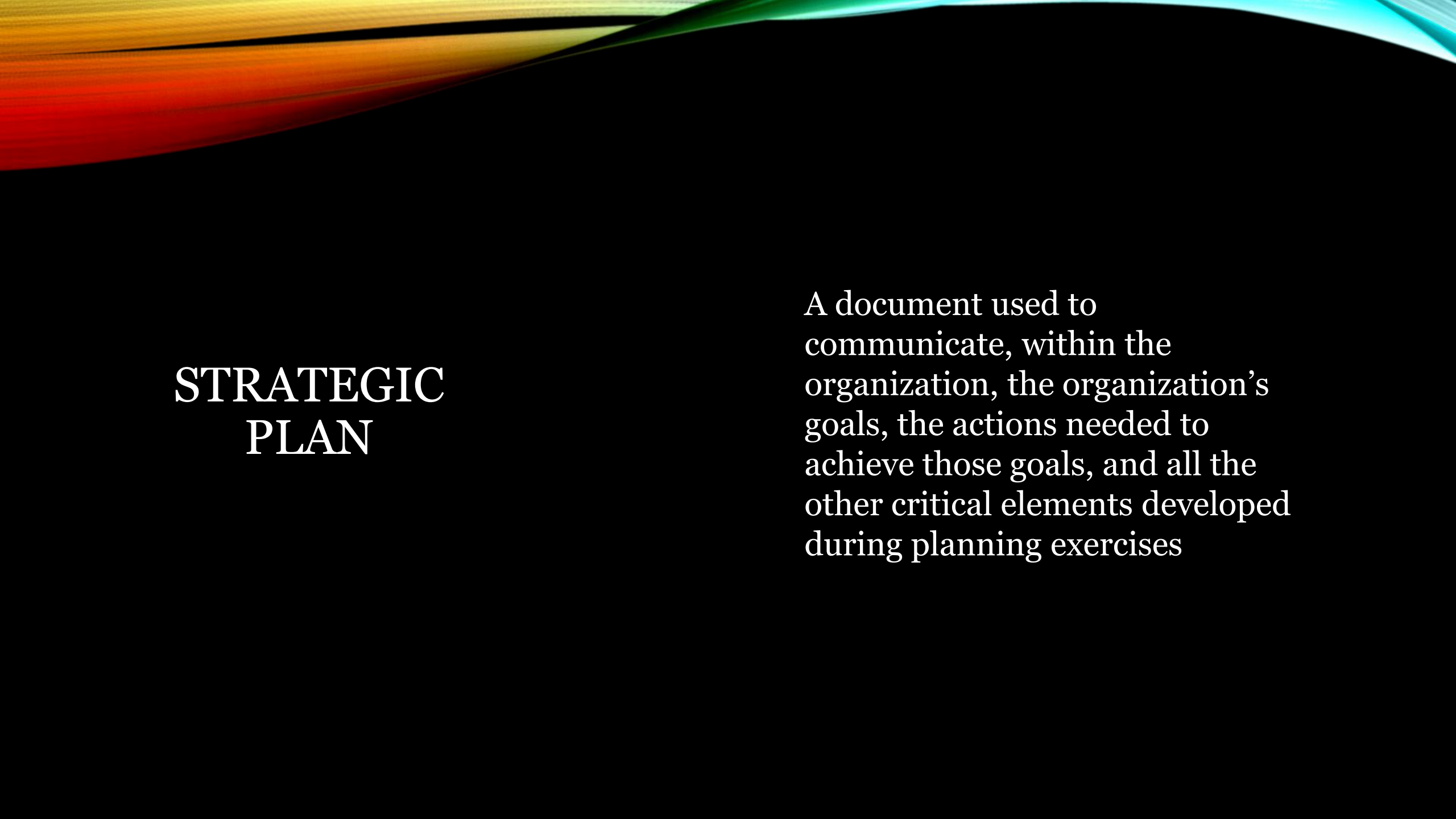


INFORMATION TECHNOLOGY (IT)

Applied computer systems, both hardware and software, and often including networking and telecommunications, usually in the context of a business or other enterprise. IT is often the name of the part of an enterprise that deals with all things electronic

STAKEHOLDER

A person, a group, or an organization that has interest or concern in an organization. Stakeholders can affect or can be affected by the organization's actions, objectives, and policies. Some examples of stakeholders are creditors, directors, employees, government (and its agencies), owners (shareholders), suppliers, unions, and the community from which the business draws its resources



STRATEGIC PLAN

A document used to communicate, within the organization, the organization's goals, the actions needed to achieve those goals, and all the other critical elements developed during planning exercises



C-LEVEL

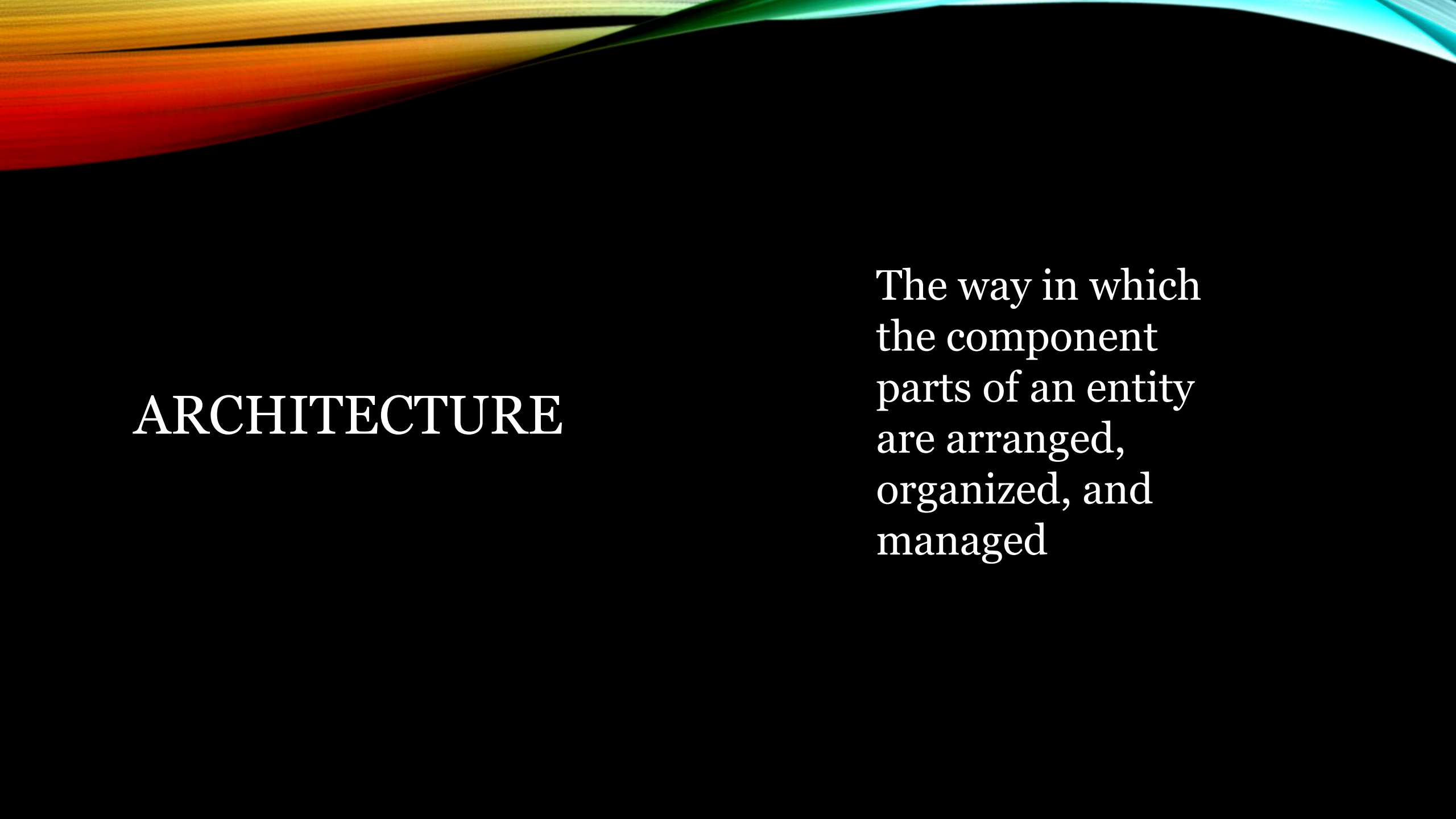
Chief level. Refers to high-ranking executives in an organization.

Officers who hold C-level positions set the company's strategy, make high-stakes decisions, and ensure that the day- to-day operations align with fulfilling the company's strategic goals



INFORMATION SECURITY ARCHITECTURE

An embedded, integral part of the enterprise architecture that describes the structure and behavior for an enterprise's security processes, information security systems, personnel, and organizational sub-units, showing their alignment with the enterprise's mission and strategic plans



ARCHITECTURE

The way in which
the component
parts of an entity
are arranged,
organized, and
managed



ENTERPRISE ARCHITECTURE

The systems, infrastructure, operations, and management of all information technology throughout an enterprise. The architecture is typically organized as high-level internally compatible representations of organizational business models, data, applications, and information technology infrastructure

INFORMATION SECURITY GOVERNANCE

NIST SP 800-100, *Information Security Handbook: A Guide for Managers*, defines information security governance as follows:

*“The process of **establishing and maintaining a framework** and supporting management structure and **processes to provide assurance** that information security strategies are aligned with and **support business objectives**, are **consistent with applicable laws** and regulations through adherence to policies and internal controls, and provide assignment of responsibility, all in an effort to manage risk. “*

ITU-T X.1054, *Governance of Information Security*, defines information security governance as:

*“The **system** by which an organization’s information security-related activities are **directed and controlled**.”*

INFORMATION SECURITY MANAGEMENT

- ISO 27000 defines *information security management* as follows:

“The supervision and making of decisions necessary to achieve business objectives through the protection of the organization’s information assets. Management of information security is expressed through the formulation and use of information security policies, procedures and guidelines, which are then applied throughout the organization by all individuals associated with the organization.”

INFORMATION SECURITY IMPLEMENTATION/OPERATIONS

- *Information security implementation/operations* can be defined in this fashion:

“The implementation, deployment and ongoing operation of security controls **defined within a cybersecurity framework.**”

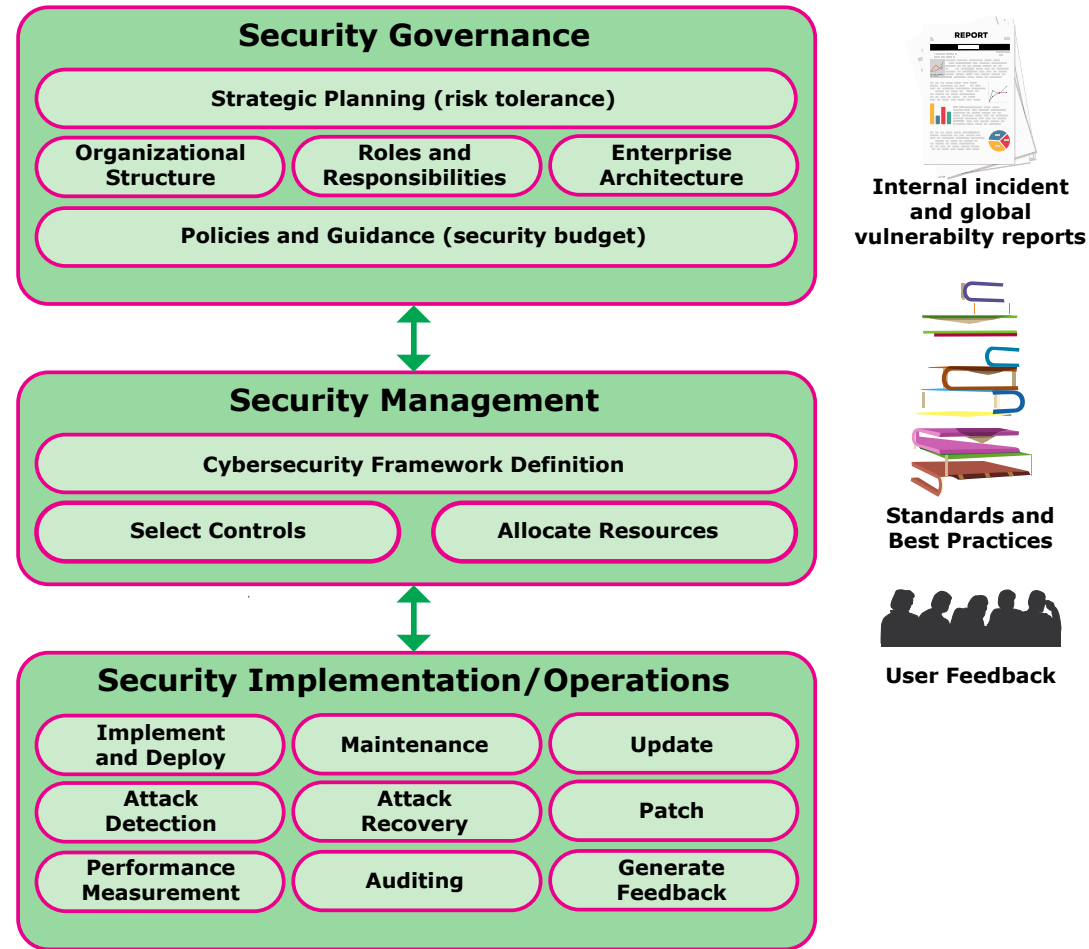


Figure 2.1 Information Security Management System Elements

X.1054 INFORMATION SECURITY GOVERNANCE PRINCIPLES

X.1054 lays out as a key objective of information security governance the alignment of information security objectives and strategy with overall business objectives and strategy

X.1054 lists six principles for achieving this objective:

- **Establish organization wide information security**
 - Management at all levels should ensure that information security is integrated with **information technology (IT)** and other activities. Top-level management should ensure that information security serves overall business objectives and should establish responsibility and accountability throughout the organization
- **Adopt a risk-based approach**
 - Security governance, including allocation of resources and budgets, should be based on the risk appetite of an organization, considering loss of competitive advantage, compliance and liability risks, operational disruptions, reputational harm, and financial loss
- **Set the direction of investment decisions**
 - Security governance entails ensuring that information security is integrated with existing organization processes for capital and operational expenditure, for legal and regulatory compliance, and for risk reporting
- **Ensure conformance with internal and external requirements**
 - External requirements include mandatory legislation and regulations, standards leading to certification, and contractual requirements. Internal requirements comprise broader organizational goals and objectives. Independent security audits are the accepted means of determining and monitoring conformance
- **Foster a security-positive environment for all stakeholders**
 - Security governance should be responsive to **stakeholder** expectations, keeping in mind that various stakeholders can have different values and needs. The governing body should take the lead in promoting a positive information security culture, which includes requiring and supporting security education, training, and awareness programs
- **Review performance in relation to business outcomes**
 - Governance executives should mandate reviews of a performance measurement program for monitoring, audit, and improvement that links information security performance to business performance

DESIRED OUTCOMES

The IT Governance Institute defines five basic outcomes of information security governance that lead to successful integration of information security with the organization's mission:

- **Strategic alignment:**
 - The support of strategic organizational objectives requires that information security strategy and policy be aligned with business strategy
- **Risk management:**
 - The principal driving force for information security governance is risk management, which involves mitigating risks and reducing or preventing potential impact on information resources
- **Resource management:**
 - The resources expended on information security (e.g., personnel time and money) are somewhat open ended and a key goal of information security governance is to align information security budgets with overall enterprise requirements
- **Value delivery:**
 - Not only should resources expended on information security be constrained within overall enterprise resource objectives, but also information security investments need to be managed to achieve optimum value
- **Performance measurement:**
 - The enterprise needs metric against which to judge information security policy to ensure that organizational objectives are achieved

SECURITY GOVERNANCE COMPONENTS

SP 800-100
lists the
following key
activities, or
components
that constitute
effective
security
governances:

Strategic planning

Organizational structure

Establishment of roles and responsibilities

Integration with the enterprise architecture

Documentation of security objectives in policies and guidance

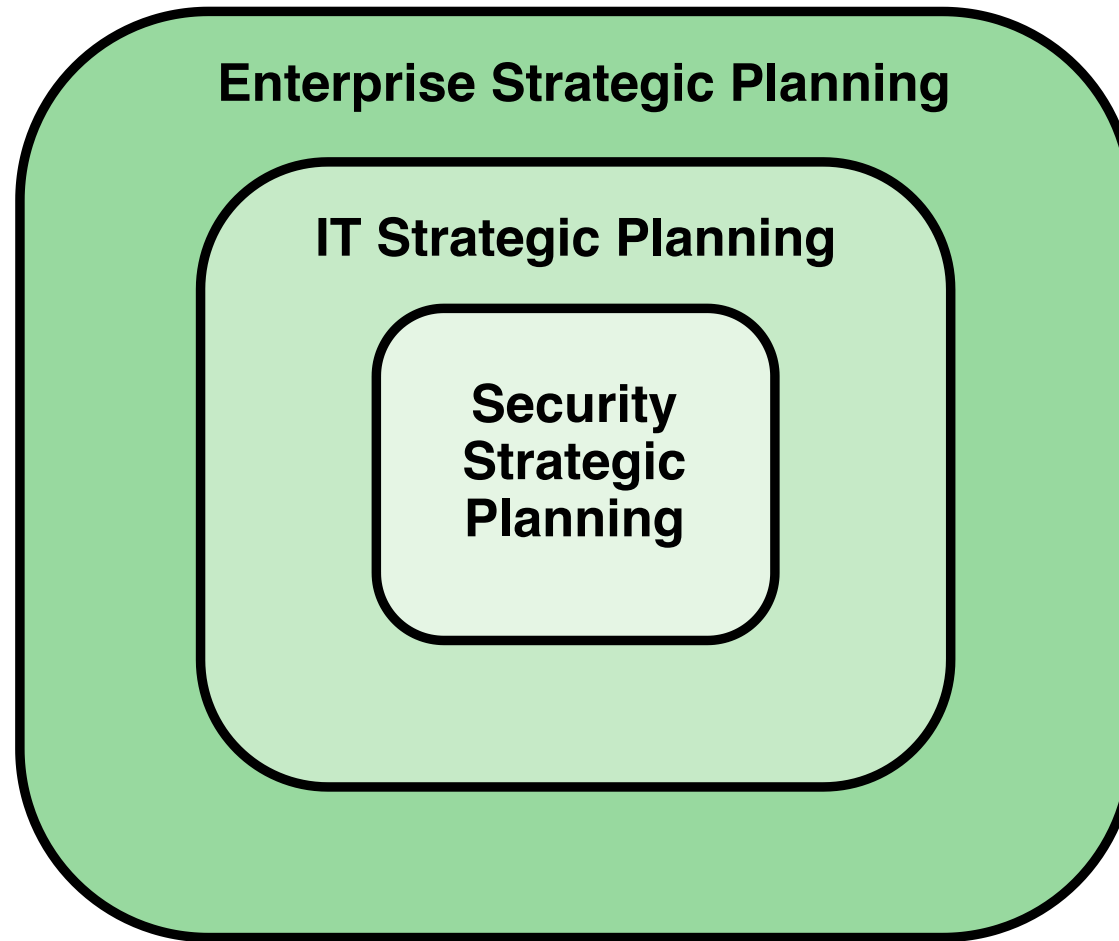


Figure 2.2 Strategic Planning

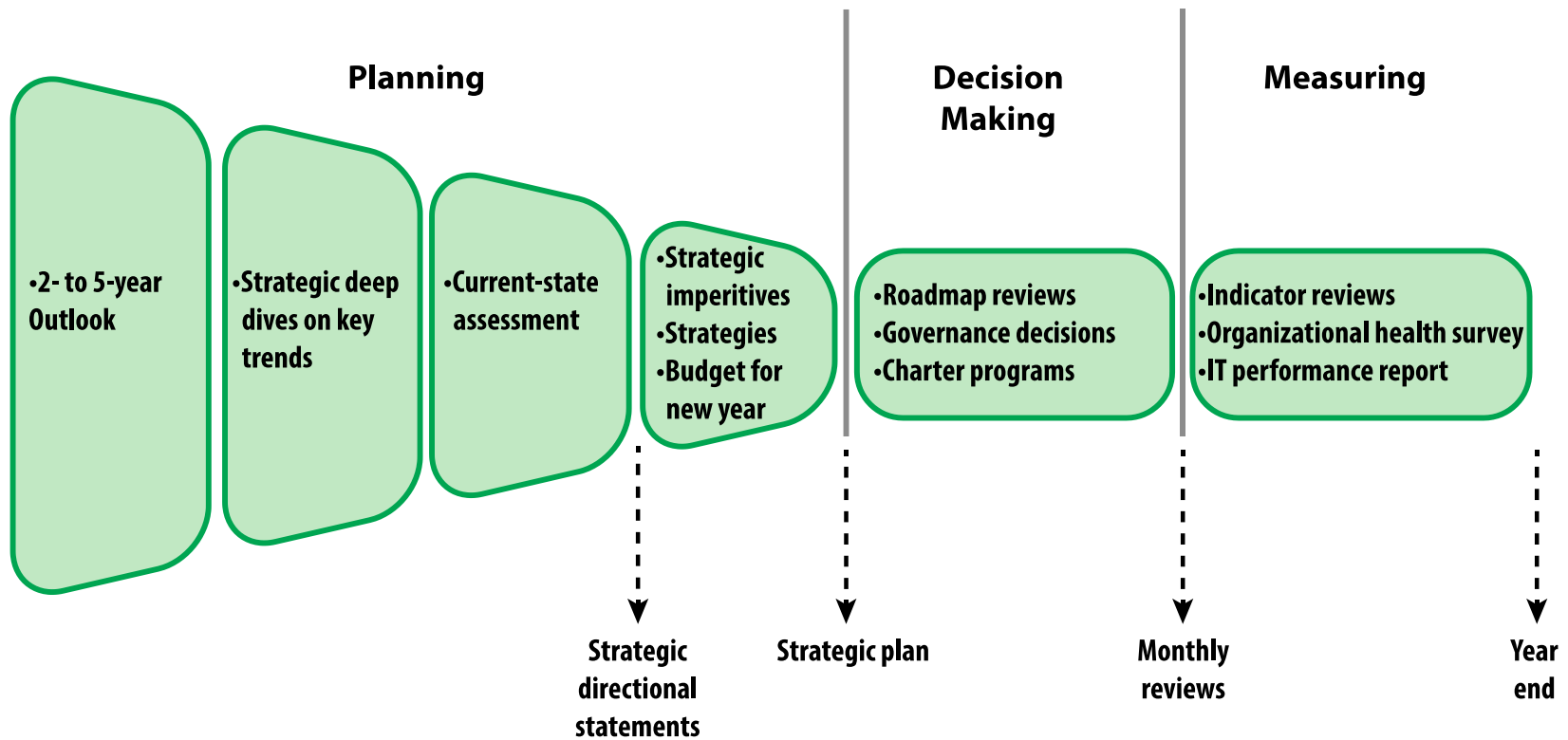


Figure 2.3 Intel's IT Strategic Planning Process

INFORMATION SECURITY STRATEGIC PLANNING

- **Alignment** of information security management and operation **with** enterprise and **IT strategic planning**
- IT security is a concern at all levels of an organization's governance and decision-making processes
- The **pervasive use and value of IT** within organizations has resulted in an expanded **notion of IT's delivery** of value to the organization to include mitigation of the organization's risk
- Is an essential component of strategic planning

Table 2.1

Elements of a Strategic Plan Document

Section	Description
Definition	
Mission, vision, and objectives	Defines the strategy for aligning the information security program with organization goals and objectives, including the role of individual security projects in enabling specific strategic initiatives.
Priorities	Describes factors that determine strategy and the priorities of objectives.
Success criteria	Define success criteria for information security program. Includes risk management, resilience, protection against adverse business impacts.
Integration	Strategy for integrating security program with organization's business and IT strategy.
Threat defense	Describe how security program will defend the organization against security threats.
Execution	
Operations plan	An annual plan to achieve agreed objectives that involves agreeing budgets, resources, tools, policies and initiatives, which: (a) can be used for monitoring progress and communicating with stakeholders; and (b) ensures that information security is included from the outset within each relevant project.
Monitoring plan	Plan for maintaining a stakeholder feedback loop; measure progress against objectives; and ensuring strategic objectives remain valid and in line with business needs.
Adjustment plan	Plan to ensure strategic objectives remain valid and in line with business needs; and procedures to communicate the value.
Review	
Review plan	Describe procedure and individuals/committees involved in regular review of information security strategy.

(Table is on page 50 in the textbook)

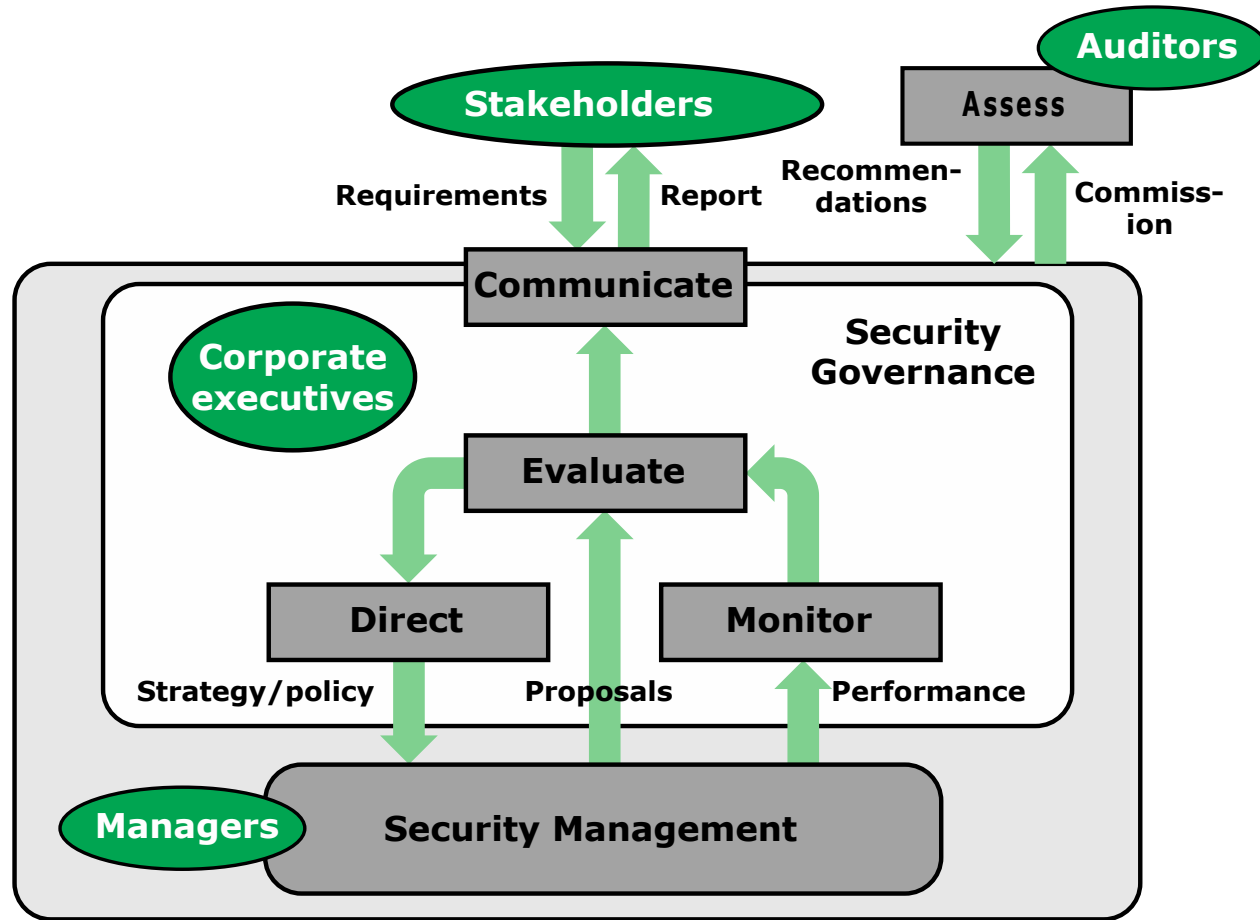


Figure 2.4 Framework for Security Governance

ORGANIZATIONAL STRUCTURE

- **Framework includes the governing cycle to direct, monitor, and evaluate the ISMS**
- The evaluation incorporates both the results of the monitoring and proposals from security management to dictate changes and improvements
- This cycle is in accordance with Requirement 4.4 in ISO 27001 that the **organization shall establish, implement, maintain, and continually improve an ISMS**
- The evaluate function triggers communication with stakeholders in the form of a report, which can be issued annually, more frequently, or based on a security incident
- As indicated in the Information Security Governance Framework, reporting to stakeholders serves two purposes:
 - Accountability
 - Effect on corporate value

REPORTING

Accountability

- Reporting enables stakeholders to ensure that information security is being managed effectively, and it should include the following:
 - Information security policy
 - Risk evaluation
 - Risk measures and response
 - Management systems

Effect on corporate value

- Reporting should disclose the following:
 - Estimates of **the costs and benefits** of making an inventory of information assets
 - Estimates of **the value of an inventory** of information assets that is developed as a result of information security activities
 - The **extent to which information security activities increase the brand value** as well as the trust of the customers and partners
 - The **economic value** of protected information **assets**
 - The **amount by which the security implementation reduces the risk** of damaging the information assets

INFORMATION SECURITY STATUS REPORT STRUCTURE

X.1054 provides an example of
information security status
report structure that includes
the following detailed contents:

Introduction

Overall status

Updates

Significant
issues (if any)

Decision(s)
required (if any)

ROLES AND RESPONSIBILITIES

- A key aspect of security governance is defining the roles and responsibilities of executives related to information security
- Executive positions that play a role in security governance include the following:
 - **Chief executive officer (CEO):** Responsible for the success or failure of the organization
 - **Chief operating officer (COO):** Generally second in command to the CEO. Oversees the organization's day-to-day operations on behalf of the CEO, creating the policies and strategies that govern operations
 - **Chief information officer (CIO):** In charge of IT strategy and the computer, network, and third-party (for example, cloud) systems required to support the enterprise's objectives and goals
 - **Chief security officer (CSO) or chief information security officer (CISO):** Tasked with ensuring data and systems security. In some larger enterprises, the two roles are separate, with a CSO responsible for physical security and a CISO in charge of digital security
 - **Chief risk officer (CRO):** Charged with assessing and mitigating significant competitive, regulatory, and technological threats to an enterprise's capital and earnings
 - **Chief privacy officer (CPO):** Charged with developing and implementing policies designed to protect employee and customer data from unauthorized access

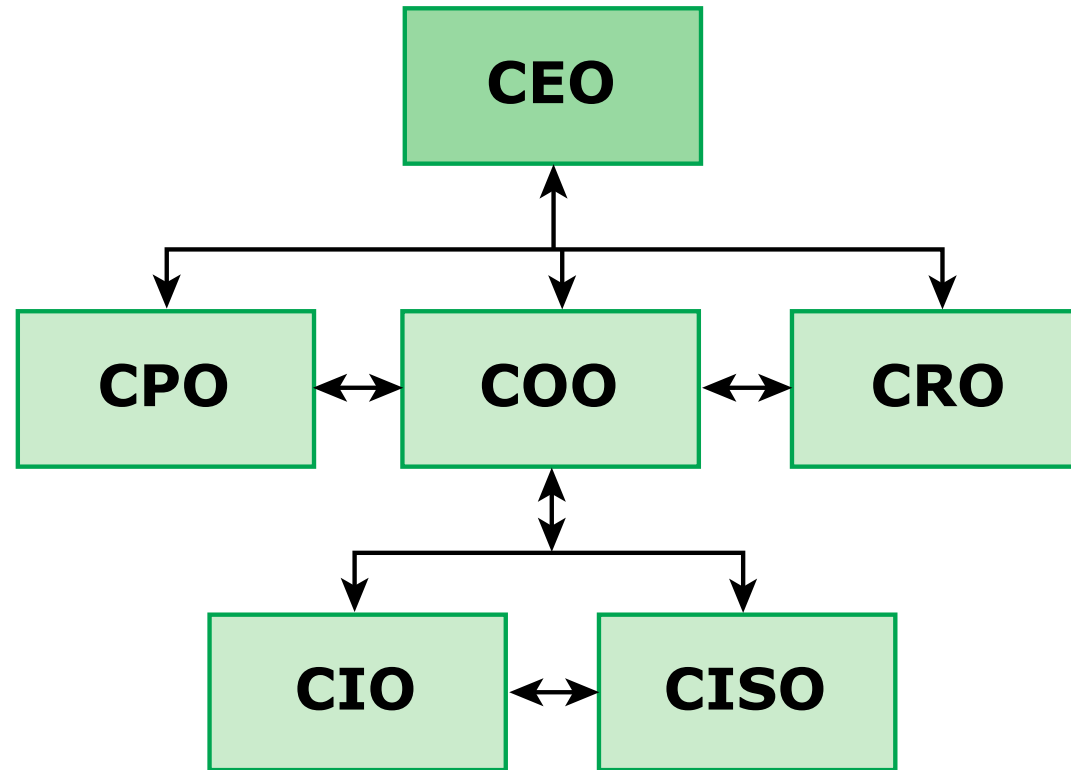


Figure 2.5 Possible Reporting Relationships for Security Governance

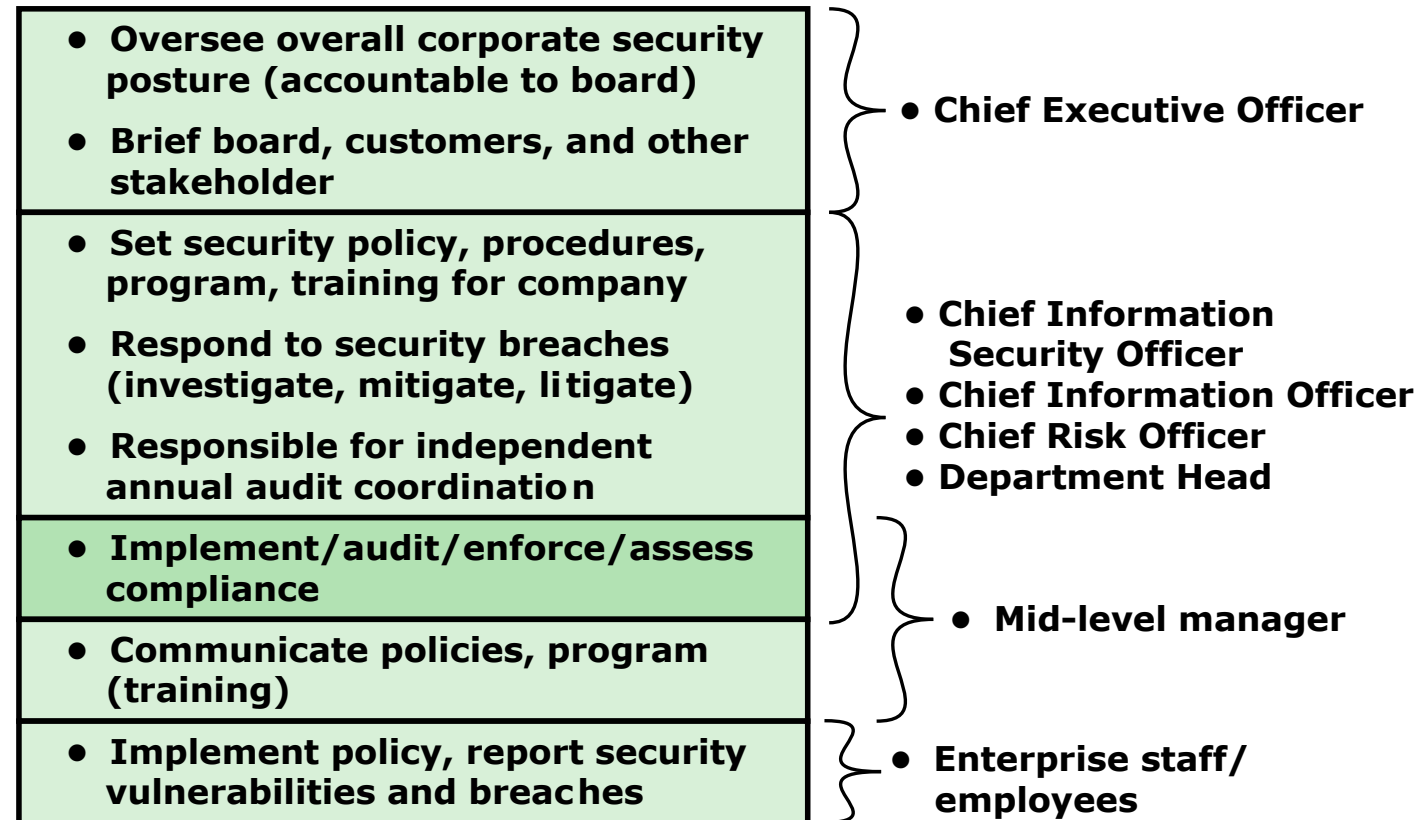


Figure 2.6 Example of Security Governance Roles and Responsibilities

Governance/Business Drivers	Roles and Responsibilities	Metrics/Audit
Corporate Executive		
Legislation, ROI	•Oversight and coordination of policies •Oversight of business unit compliance •Compliance reporting •Actions to enforce accountability	Financial reporting, monetizing losses, conforming to policies
Business Unit Head		
Standards, policies, budgets	•Provide information security protection commensurate with the risk and business impact •Provide security training •Develop the controls environment and activities •Report on effectiveness of policies, procedures, and practices	Policy violations, misuse of assets, internal control violations
Senior Manager		
Standards, audit results	• Provide security for information and systems •Periodic assessments of assets and their associated risks •Determine level of security appropriate •Implement policies and procedures to cost-effectively reduce risk to acceptable levels •Periodic test of security and controls	Risk assessment and impact analysis, control environment activities, remedial actions, policy and procedure compliance, security and control test results
CIO/CISO		
Security policies, security operations, and resources	•Develop, maintain, and ensure compliance to program •Designate security officer with primary duties and training •Develop required policies to support security program and business-unit-specific needs •Assist senior managers with their security responsibilities •Conduct security awareness	Security awareness effectiveness, incident response and impact analysis, security program effectiveness, information integrity, effects on information processing

Table 2.2

Information Security Governance Responsibilities

(Table is on pages 57-58 in the textbook)

INTEGRATION WITH ENTERPRISE ARCHITECTURE

A key element of security governance is the development of an information security architecture

The architecture provides information on how security capabilities are placed and used in the enterprise architecture

It allocates security requirements and controls to common services or infrastructures

Provides a foundation for achieving risk-appropriate information system security, determining what circumstances and which security controls apply to information systems

FEDERAL ENTERPRISE ARCHITECTURE FRAMEWORK (FEAF)

The most comprehensive of
all the enterprise
architectures in use

Developed for use by U.S.
federal agencies

Is used effectively as a
governance tool by other
government organizations,
private enterprises,
nonprofit groups, and other
organizations

The FEAF provides:

- A perspective on how enterprise architectures are viewed in terms of sub-architecture domains
- Six reference models for describing different perspectives of the enterprise architecture
- A process for creating an enterprise architecture
- A transitional process for migrating from a pre-enterprise architecture to a post-enterprise architecture paradigm
- A taxonomy for cataloging assets that fall within the purview of the enterprise architecture
- An approach to measuring the success of using the enterprise architecture to drive business value

DOMAIN ARTIFACTS

High-level artifacts

These document strategic plans and objectives, typically in the form of policy statements and diagrams

Mid-level artifacts

These document organizational procedures and operations, such as services, supply chain elements information flows, and IT and network architecture

Typical artifacts at this level are narrative description, flowcharts, spreadsheets, and diagrams

Low-level EA artifacts

These document the specific resources, such as applications, interfaces, data dictionaries, hardware, and security controls

Typical artifacts at this level are detailed technical specifications and diagrams



The FEAF describes six domains:

- Strategy
- Business
- Data and information
- Enabling applications
- Host and infrastructure
- Security

Table 2.3 Enterprise Architecture Reference Models

Reference Model (RM)	Elem ents	Goals/Benefits
Performance (PRM)	Goals; Measurement Areas; Measurement Categories	Improved organizational performance and governance; Cost benefits
Business (BRM)	Mission sectors; functions; services	Organization transformation; Analysis, design, and reengineering
Data (DRM)	Domain; Subject; Topic	Data quality/re-use; Information sharing; Agile development
Application (ARM)	System; Component; Interface	Application portfolio management; Cost benefits
Infrastructure (IRM)	Platform; Facility; Network	Asset management standardization; Cost benefits
Security (SRM)	Purpose; Risk; Control	Secure business/IT environment

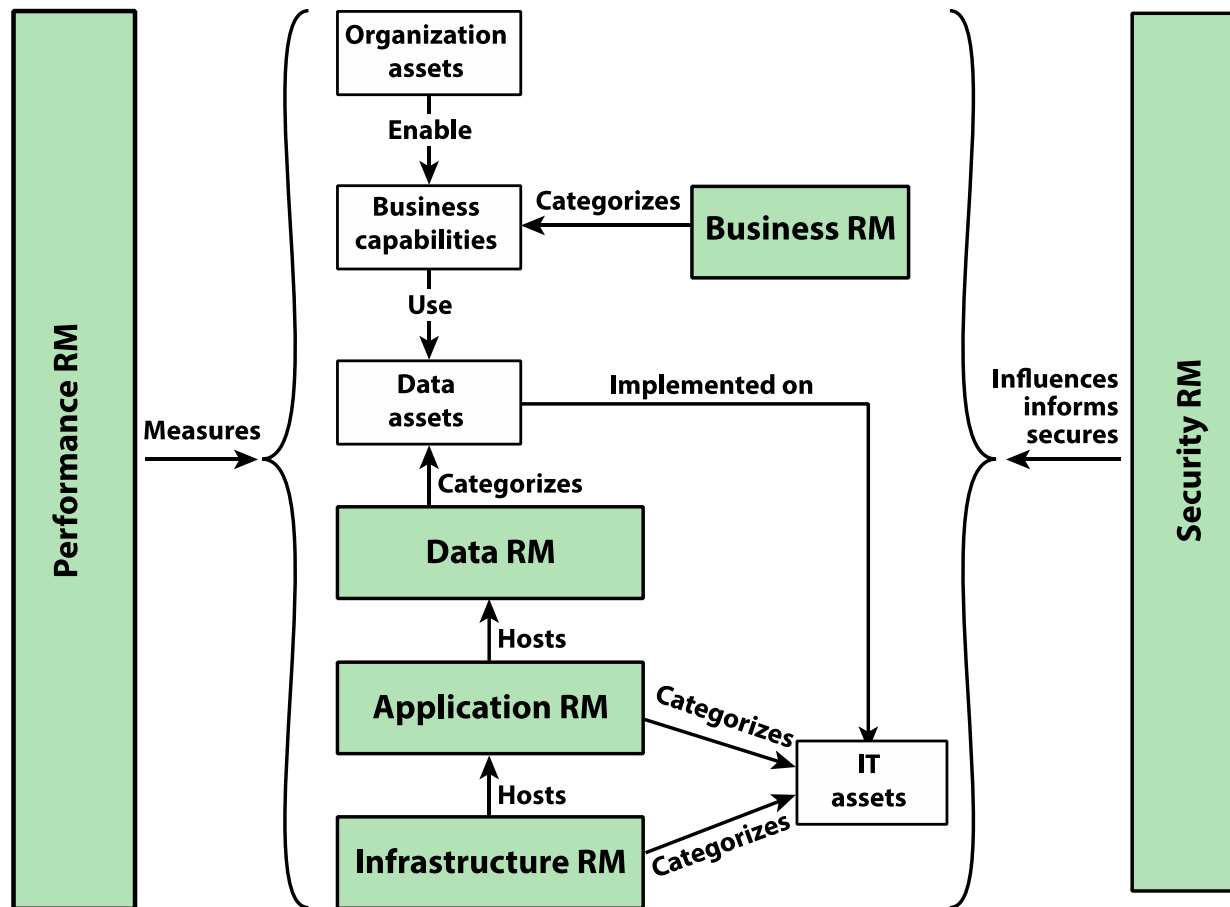


Figure 2.7 Relationship Between Reference Model (RM) Components

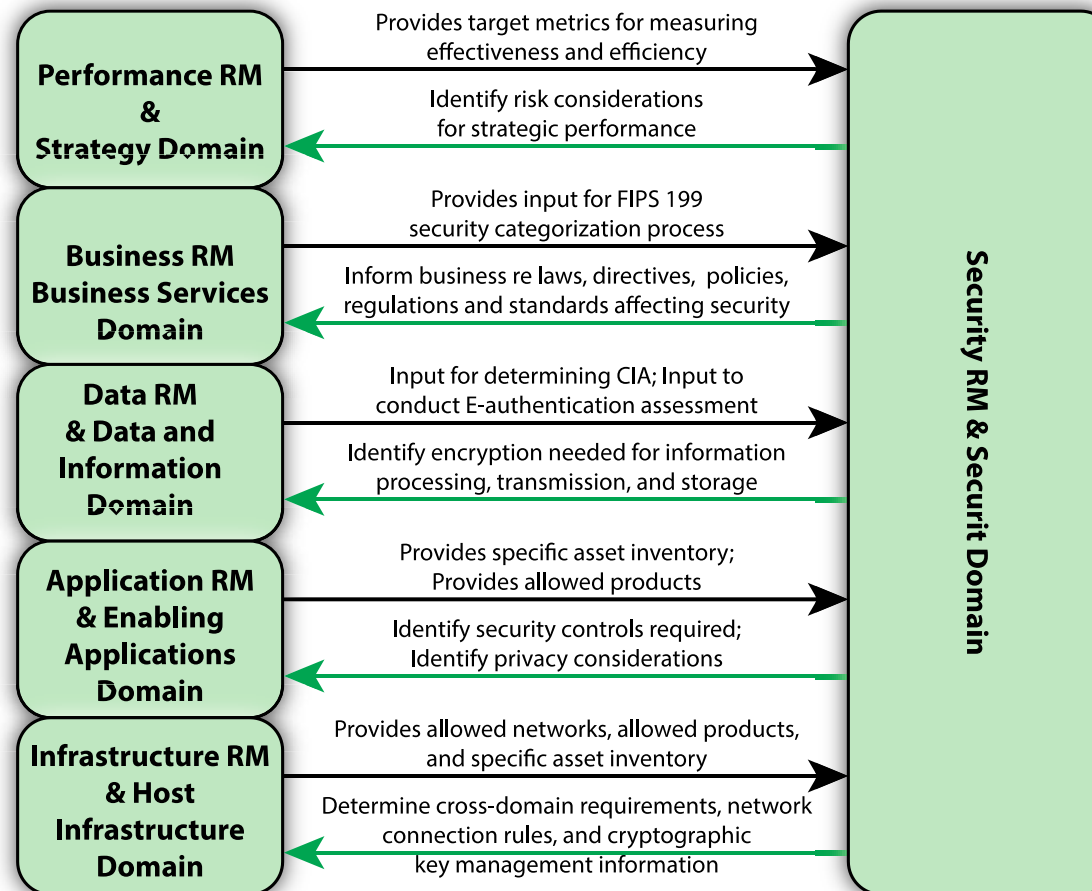


Figure 2.8 Interaction Between Security Reference Model and Other Reference Models

POLICIES AND GUIDANCE

- NIST SP 800-53, *Security and Privacy Controls for Federal Information Systems and Organizations*, defines an information security policy as:
 - “an aggregate of directives, rules, and practices that prescribes how an organization manages, protects, and distributes information”
- It is an essential component of security governance, providing a concrete expression of the security goals and objectives of the organization
- The policies, together with guidance documents on the implementation of the policies, are put into practice through the appropriate selection of controls to mitigate identified risks
- The policies and guidance need to cover information security roles and responsibilities, a baseline of required security controls, and guidelines for rules of behavior for all users of data and IT assets

SECURITY GOVERNANCE FRAMEWORK

The definition, monitoring, and maintenance of a security governance framework entails a number of tasks:

Appoint a single executive to be ultimately responsible for security governance

Decide and communicate to top executives the objectives of the security governance framework

Ensure integration of the security architecture with the enterprise architecture

Include a process that enables the governing body to evaluate the operation of the information security strategy

Regularly review the organization's risk appetite to ensure that it is appropriate for the current environment in which the organization operates

Formally approve the information security strategy, policy, and architecture

SECURITY DIRECTION

A governing body, typically consisting of those individuals ultimately responsible for what the organization does, is responsible for ensuring that there is effective security direction

The Information Security Forum's (ISF's) Standard of Good Practice for Information Security (SGP) recommends that effective security direction be provided by a combination of a single individual responsible for information security supported by a governing body

The single individual is a CISO or equivalent executive whose responsibilities implementing the organization's overall approach and ensuring that a security mind-set permeates the organization

The SGP also recommends that the governing body include the CISO and have a mission to support the CISO as well as review the activities that are under the CISO's direction

Other members of the governing body could include the CIO, key department heads, and heads of business support functions such as human resources

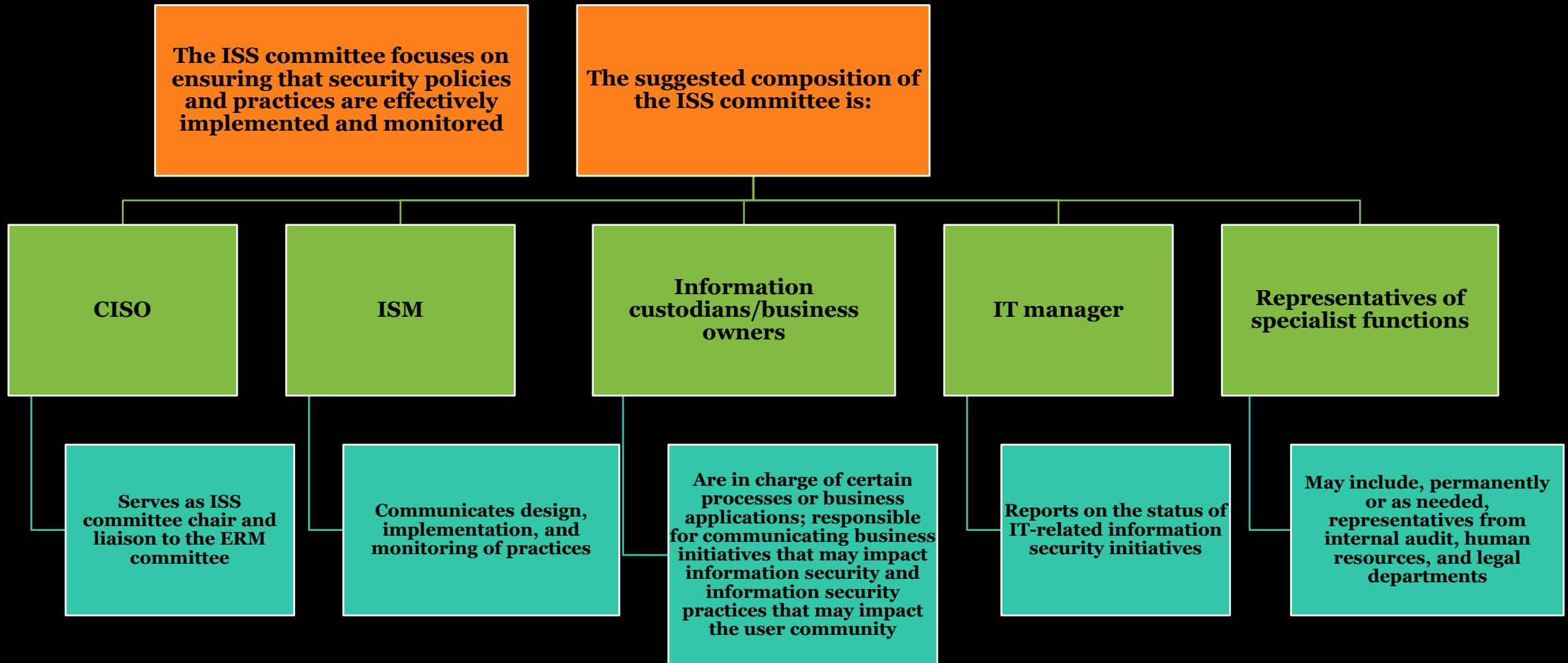
The governing body assists in the coordination of security activities and ensuring that the CISO has the resources and authority required to effect needed changes

In addition, the governing body reports security status and plans to the stakeholders

COBIT 5 GOVERNING BODY STRUCTURE

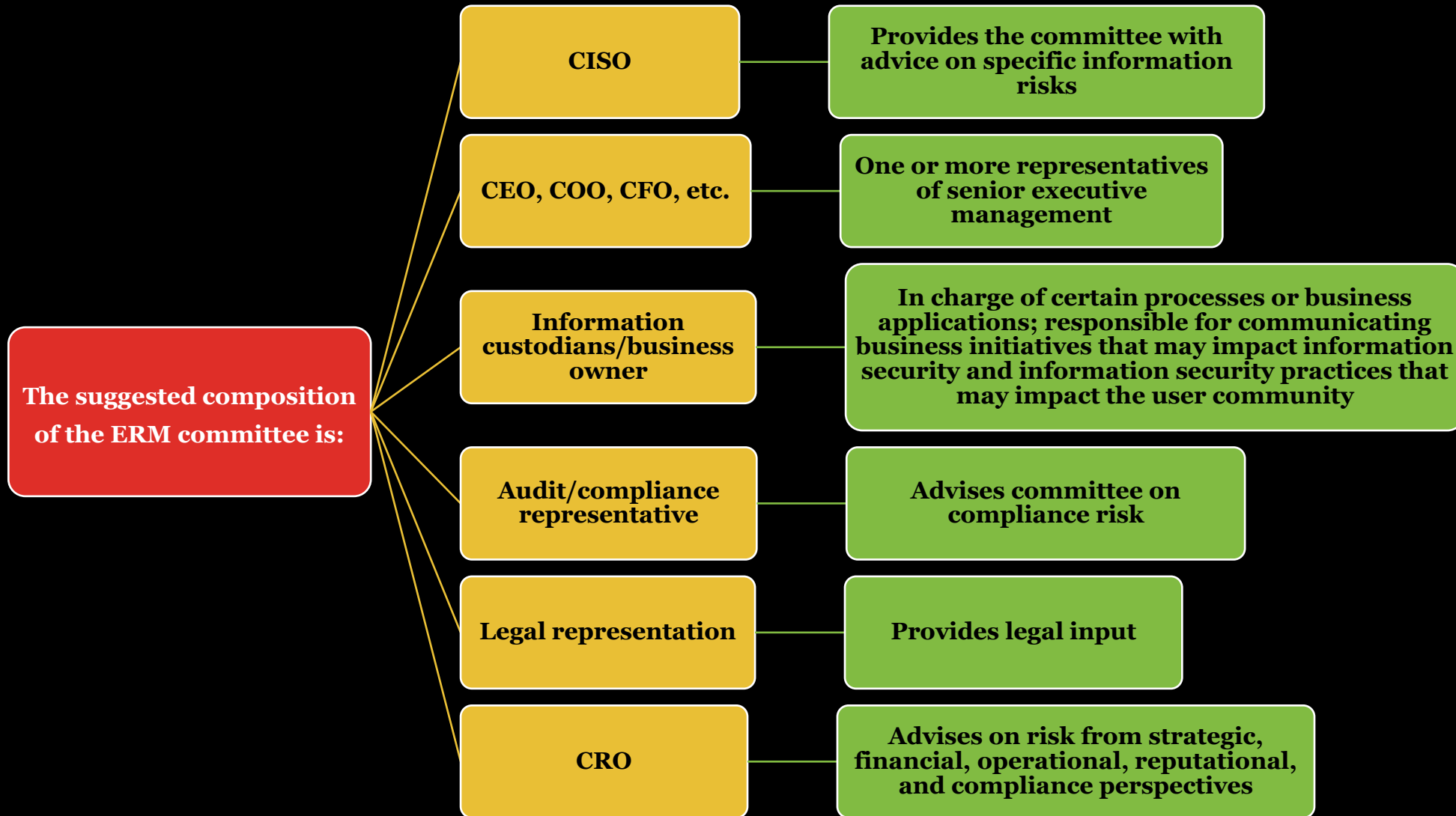
- COBIT 5 distinguishes five distinct roles/structures:
 - **Chief Information Security Officer (CISO)**
 - Has overall responsibility for the enterprise information security program
 - Is the liaison between executive management and the information security program
 - **Information Security Steering (ISS) Committee**
 - Ensures, through monitoring and review, that good practices in information security are applied effectively and consistently throughout the enterprise
 - **Information Security Manager (ISM)**
 - Has overall responsibility for the management of information security efforts, including application security, infrastructure security, access management, threat and incident management, risk management, awareness program, metrics, and vendor assessments
 - **Enterprise Risk Management (ERM) Committee**
 - Responsible for the decision making of the enterprise to assess, control, optimize, finance, and monitor risk from all sources for the purpose of increasing the enterprise's value to its stakeholders
 - **Information Custodians/Business Owners**
 - Serve as liaisons between the business and information security functions

COBIT 5 ISS COMMITTEE



COBIT 5

ERM COMMITTEE



RACI CHARTS

- Responsible, Accountable, Consulted, Informed
- The COBIT responsibility model is formalized through a RACI chart matrix attached to all 34 COBIT processes
 - **Responsible**
 - A person doing an activity and expected to deliver or submit the assigned work portion within the given deadlines
 - **Accountable**
 - A person with decision-making authority and who is expected to ensure the successful completion of project work
 - **Consulted**
 - A stakeholder who should be included in any decision making or work activity by being consulted prior to the decision or action
 - **Informed**
 - A person who needs to know of decision making or actions after they occur



RACI charting
helps avoid
these problems:

- Unclear accountability between individuals or departments
- Redundancies or work not being accomplished
- Delayed or incomplete work
- Inadequate communication and/or coordination
- Unclear approval/decision-making processes

Table 2.4 Partial COBIT 5 RACI Chart for Organizational Structures

Activity	CISO	ISSC	ISM	ERM	IC/BO
Identify and communicate information security threats, desirable behaviors and changes needed to address these points.	A		R		
Ensure that environmental and facilities management adheres to information security requirements.	A		R		
Provide ways to improve efficiency and effectiveness of the information security function (e.g., through training of information security staff; documentation of processes, technology and applications; and standardization and automation of the process).	A		R		
Define and communicate an information security strategy that is in line with the business strategy.	R	A			
Research, define and document information security requirements.	R	A			
Validate information security requirements with stakeholders, business sponsors and technical implementation personnel.	R	A			
Develop information security policies and procedures.	R	A			
Define and implement risk evaluation and response strategies and co-operate with the risk office to manage the information risk.	R			A	
Ensure that potential impact of changes is assessed.	R	A			
Collect and analyze performance and compliance data relating to information security and information risk management.	R		R		
Raise the profile of the information security function within the enterprise and potentially outside the enterprise.		R			R

A = accountable

R = responsible

IC/BO = Information custodians/ business owners

(Table is on page 67 in the textbook)

Indicator Category	Indicators
Executive Management Support	Executive management understand the relevance of information security to the organization Executives promote effective information security governance Executives actively support the information security program Executives comply with all aspects of the information security program Executive management understands their responsibility for information security Executives understand the liability associated with not executing information security responsibilities
Business and Information Security Relationship	Security investments are optimized to support business objectives Business process owners actively support the information security program Business process owners view security as an enabler Business process owners are involved in evaluating security alternatives Business process owners actively support the development of a security culture Business process owners accept responsibility for information security Business process owners are accountable for information security
Information Protection	All information in use within the organization is identified Information is classified according to criticality Information is classified according to sensitivity Information classifications are enforced Information classifications are applied to information received from outside entities Information classifications are applied to information provided to an outside entity Ownership responsibilities for all information is assigned Applications that process sensitive information are identified Applications that support critical business processes are identified Data retention standards are defined and enforced

TABLE 2.5

INDICATORS OF
INFORMATION
SECURITY
GOVERNANCE
EFFECTIVENESS

(TABLE IS ON PAGE 68 IN THE TEXTBOOK)

METRICS CATEGORIES

EXECUTIVE MANAGEMENT SUPPORT

- A critical component for cybersecurity program success
- If top executives exhibit an understanding of security issues and take an active role in promoting security, this influence is felt throughout the firm
- Strong executive management security awareness and support promotes a culture of secure practices

BUSINESS AND INFORMATION SECURITY RELATIONSHIP

- An effective security governance program conveys a strong relationship between business goals and objectives and information security
- When information security is incorporated into the enterprise planning process, employees tend to feel a greater responsibility for the security of their assets and view security not as an impediment but as an enabler

INFORMATION PROTECTION

- These indicators of security governance effectiveness deal with the pervasiveness and strength of information security mechanisms
- These indicators reflect the degree of awareness of information security issues and the level of preparedness, enterprise-wide, to deal with attacks

SECURITY GOVERNANCE BEST PRACTICES

The ISF SCP breaks down the best practices in the security governance category into two areas and five topics:

Security Governance Approach

- This area provides guidance for establishing, maintaining, and monitoring an information security governance framework, which enables the organization's governing body to set clear direction for and demonstrate their commitment to information security and risk management
 - Security Governance Framework
 - This topic provides a checklist of action for establishing a security governance framework and ensuring that the organization's overall approach to information security supports high standards of governance
 - Security Direction
 - This topic outlines a recommended top-down management structure and mechanism for coordinating security activity and supporting the information security governance approach. It includes discussion of a CISO, a working group, and the tasks of each

• Security Governance Components

- This area provides guidance for supporting the information security governance framework by creating an information security strategy and implementing an information security assurance program that are aligned with the organization's strategic objectives
 - Information Security Strategy
 - Provides a checklist for developing an information security strategy
 - Stakeholder Value Delivery
 - Focuses on how the organization should implement processes to measure the value delivered by information security initiatives and report the results to all stakeholders
 - Information Security Assurance
 - Discusses actions to assure that information risk is being adequately addressed



SUMMARY

- The concept of security governance and how it differs from security management
- Key components of security governance
- Topics that should be covered in a strategic security plan
- Topics that should be covered in an information security report
- Roles and responsibilities that are part of security governance
- The concepts of information security architecture
- Security governance best practices